

NEXUM

Security Scan Report

Generated: 2026-05-17 17:53 UTC · Source: nodoc_security-copilot.yml

35 / 100

Tier 1 — MODERATE RISK

4 findings total · 3 HIGH · 1 MEDIUM

Top Findings

[NEXUM-004] HIGH

/graphData/details

POST /graphData/details accepts no Idempotency-Key header. Network retries or agent replays can create duplicate resources or apply the same mutation more than once without any safeguard.

[NEXUM-005] MEDIUM

/provisioning/create

POST /provisioning/create accepts a request body with 'additionalProperties: true'. An AI agent can inject arbitrary fields that the server may silently persist, forward, or act on in ways not visible in the spec.

Findings by Rule

Rule ID	Rule Name	Findings	Severity
NEXUM-004	IdempotencyMissing	3	HIGH
NEXUM-005	SchemaVolatility	1	MEDIUM

Full Findings — Grouped by Rule

NEXUM-004 — IdempotencyMissing (HIGH)

Path	Method	Severity
/graphData/details	POST	HIGH
/provisioning/create	POST	HIGH
/api/gateway/actions/containers/me	POST	HIGH

Guardrail: Add 'Idempotency-Key' as a required request header. The server must store the key and return the original response for duplicate requests received within a reasonable window.

NEXUM-005 — SchemaVolatility (MEDIUM)

Path	Method	Severity
/provisioning/create	POST	MEDIUM

Guardrail: Set 'additionalProperties: false' and enumerate every allowed property explicitly. Reject requests containing unknown fields at the API boundary before they reach business logic.

Manual Review Required

- **model_compatibility_range:** Cannot be inferred from the spec. Depends on model capabilities, deployment context, and the desired trust level for this integration.
- **auto_detected_invariants.immutable_fields:** No readOnly properties found in component schemas. Manually list any fields that must never change after resource creation.
- **auto_detected_invariants.numeric_limits:** No numeric or length constraints found in component schemas. Specify min/max bounds for any safety-critical numeric fields.